悬镜灵脉 CodeAI 代码安全智能体系统

灵脉CodeAI

报告日期: 2026-10-12

内部资料，注意保密

报告声明

悬镜灵脉 CodeAI 代码安全智能体系统是北京安普诺信息技术有限公司具有自主知识产权的软件源代码安全缺陷检测平台产品。。

本检测报告由悬镜灵脉 CodeAI 代码安全智能体系统采用智能检测引擎进行自动化检测，并对检测结果经过人工审核后产生的检测报告。北京安普诺信息技术有限公司保留对检测报告中各款项的解读权利，但并不意味着对检测结果中的缺陷或安全漏洞可能引起的任何直接经济损失或任何间接损失承担责任。

本检测报告的最终解释权归属北京安普诺信息技术有限公司。

The Xmirror Xmaze CodeAI Development Security Guard is a software source code security vulnerability detection product developed by Beijing Anpro Information Technology Co., Ltd., with independent intellectual property rights.

This report was generated by the Xmaze CodeAI sing an intelligent detection engine for automated analysis, and the results were reviewed manually before producing this report. Anpro reserves the right to interpret the items in the report, but does not assume responsibility for any direct economic loss or any indirect damage that may arise from the defects or security vulnerabilities identified in the results.

The final interpretation of this report belongs to Beijing Anpro Information Technology Co., Ltd.

北京安普诺信息技术有限公司

1. 分析预览

1.1. 报告信息

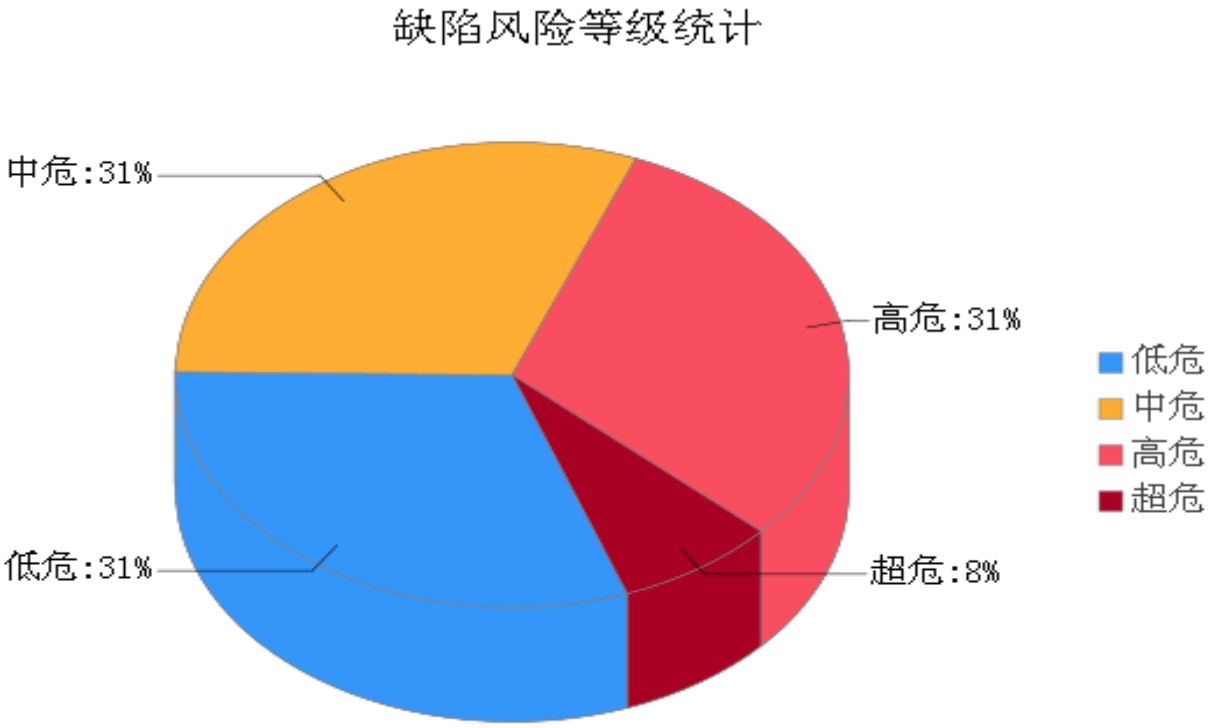
任务名称	sec-kit-e2e-demo-main
创建者	Pipeline_Test(Pipeline_Test)
检测开始时间	2026-10-12 14:07:30
检测结束时间	2026-10-12 14:09:16
源码来源	
源码语言	Shell,Text,Java/Android/JSP,Json,Python,JavaScript,OTHER
源代码行数	553
规则模板	默认模板
检测类型	代码审计

1.2. 缺陷风险等级统计

低危	4 个
中危	4 个
高危	4 个
超危	1 个

北京安普诺信息技术有限公司

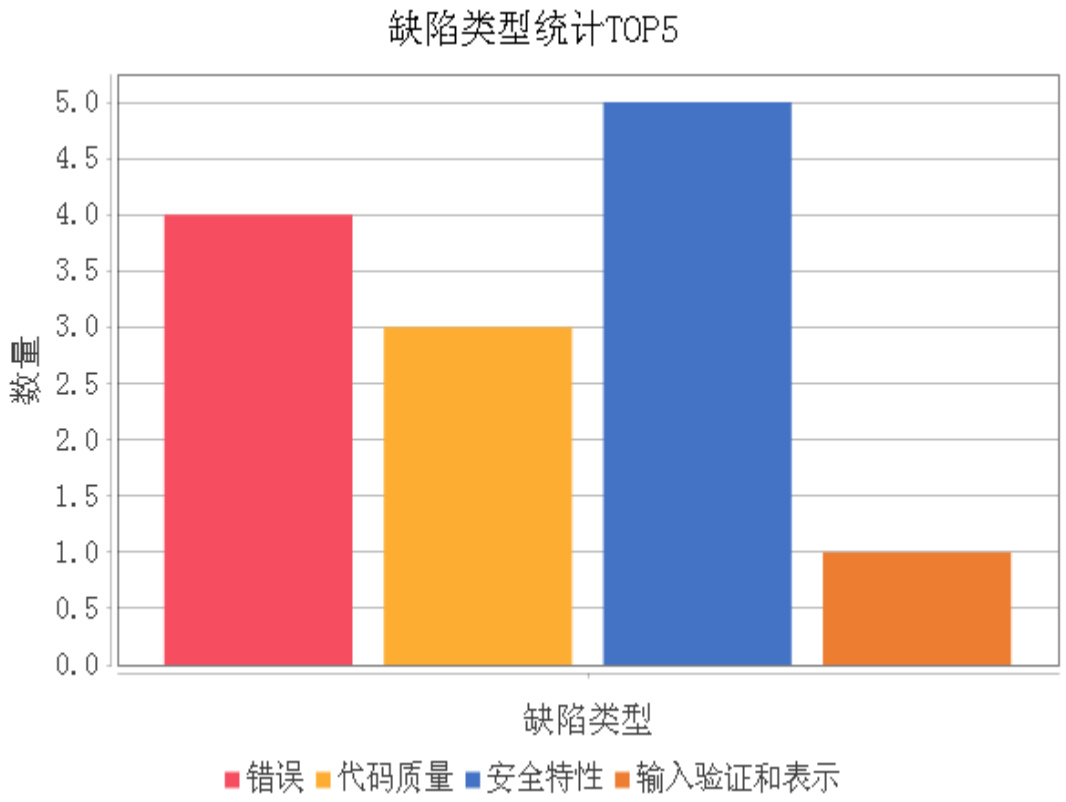
缺陷总数	**13 个**
缺陷密度	**18.81 个**



1.3. 缺陷分类统计

缺陷分类	数量
安全缺陷	**6**
编码规范	**0**
质量缺陷	**7**

1.4. 缺陷类型统计 TOP5

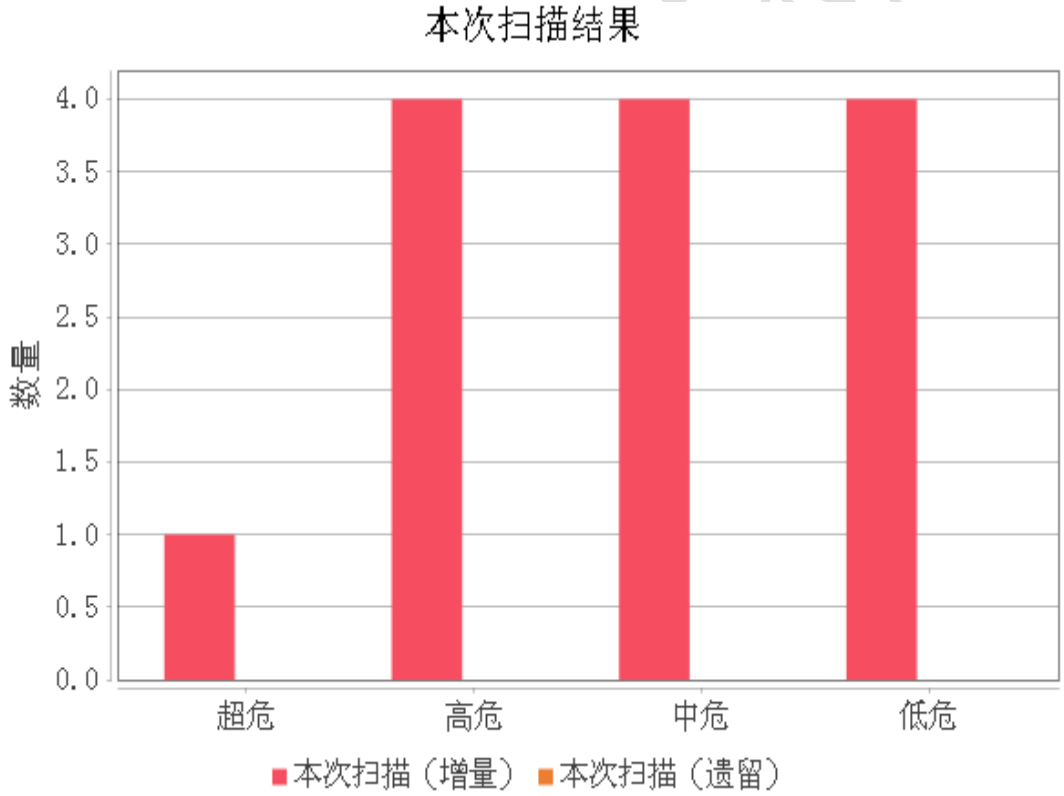


1.5. 最近两次扫描结果

上一次扫描时间：

本次扫描时间：2026-10-12 14:07:30





1.6. 缺陷审计统计

截止生成报告前审计结果如下：2026-10-12 14:07:30

审计状态	数量
未审计	13
已审计-超危	0
已审计-高危	0
已审计-中危	0
已审计-低危	0
已审计-忽略	0
已审计-误报	0
已审计-已修复	0

2. 缺陷详情

2.1. 系统风险等级-超危

2.1.1. 安全特性（安全缺陷）

缺陷名称：命令注入

缺陷数量：1

缺陷介绍：检测到在函数参数 `$FUNC` 中对 `child_process` 的调用。如果输入可由用户控制，这可能导致命令注入。尽量避免使用 `child_process` 调用，如果必须使用，确保对用户输入进行正确的过滤或沙箱化以防止安全风险。

缺陷 1：

北京安普诺信息技术有限公司

缺陷标识	2109526855518875650
风险点	js/server.js [7]
审计状态	

2.2. 系统风险等级-高危

2.2.1. 输入验证和表示（安全缺陷）

缺陷名称：跨站脚本(XSS)

缺陷数量：1

缺陷介绍：检测到使用了`eval()`函数。如果该输入来自用户提供的内容，可能会引入跨站脚本攻击（XSS）漏洞。遵循 OWASP 的最佳实践，确保在 JavaScript 环境中正确处理 XSS，可以考虑使用更安全的 API，如`JSON.parse()`来评估用户输入。

缺陷 1：

缺陷标识	2109526855481126916
风险点	python/app.py [6]
审计状态	

2.2.2. 安全特性（安全缺陷）

缺陷名称：密码管理：硬编码密码

缺陷数量：1

北京安普诺信息技术有限公司

缺陷介绍：

硬编码密码绝不是一个好主意。硬编码密码不仅允许项目的所有开发人员查看密码，而且还使解决问题变得极其困难。代码投入生产后，如果不修补软件，则无法更改密码。如果受密码保护的帐户被盗用，则系统所有者必须在安全性和可用性之间进行选择。

缺陷 1：

缺陷标识	2109526855493709826
风险点	python/app.py [3]
审计状态	

缺陷名称：密码管理：硬编码密码

缺陷数量：2

缺陷介绍：

使用硬编码密码（Hardcoded password ）是一个坏的编程习惯。这不仅是因为所有项目开发人员都可以使用通过硬编码方式处理的密码，而且还会使解决这一问题变得极其困难。一旦代码投入使用，除非对软件进行修补，否则您再也不能改变密码了。如果帐户中的密码保护减弱，系统所有者将被迫在安全性和可行性之间做出选择。

硬编码密码为攻击者提供了一个潜在的后门，由于密码被硬编码在代码中，攻击者可以利用这些密码绕过正常的认证机制，进入系统。例如，攻击者可以通过访问特定的代码段，利用硬编码密码获取系统权限，从而实现对系统的控制。

北京安普诺信息技术有限公司

缺陷 1：

缺陷标识	2109526855527264257
风险点	src/main/java/com/govee/demo/PaymentService.java [7]
审计状态	

缺陷 2：

缺陷标识	2109526855544041473
风险点	src/main/java/com/govee/demo/UserController.java [9]
审计状态	

2.3. 系统风险等级-中危

2.3.1. 代码质量（质量缺陷）

缺陷名称：未明确的编码格式

缺陷数量：1

缺陷介绍 缺少'encoding'参数。默认情况下，'open()'函数使用设备本地编码打开文件，这可能会导致包含特殊字符的文件被损坏。在以文本模式打开文件时，为了保证跨平台支持，请指定编码，例如：encoding="utf-8"。

北京安普诺信息技术有限公司

缺陷 1：

缺陷标识	2109526855489515522
风险点	python/app.py [9]
审计状态	

缺陷名称：未正确释放资源：数据库

缺陷数量：2

缺陷介绍：

程序可能无法成功释放某一项数据库资源。

资源泄露至少有两种常见的原因：

1、错误状况及其他异常情况。

2、未明确程序的哪一部份负责释放资源。

大部分 Unreleased Resource 问题只会导致一般的软件可靠性问题，但如果攻击者能够故意触发资源泄漏，该攻击者就有可能通过耗尽资源池的方式发起 denial of service 攻击。

北京安普诺信息技术有限公司

缺陷 1：

缺陷标识	2109526855535652866

风险点	src/main/java/com/govee/demo/PaymentService.java [10]
审计状态	

缺陷 2：

缺陷标识	2109526855544041479
风险点	src/main/java/com/govee/demo/UserController.java [12]
审计状态	

2.3.2. 安全特性（安全缺陷）

缺陷名称：弱密码哈希

缺陷数量：1

缺陷介绍：

MD2、MD4、MD5、RIPEMD-160、SHA-1 和 Keccak 是常用的加密哈希算法，通常用于验证消息和其他数据的完整性。然而，由于最近的密码分析研究揭示了这些算法的根本弱点，因此不应再在安全关键环境中使用它们。

破解 MD 和 RIPEMD 哈希的有效技术已广泛使用，因此不应依赖这些算法来确保安全性。对于 SHA-1，当前的技术仍然需要大量的计算能力，并且更难实现。然而，攻击者已经找到了该算法的致命弱点，破解该算法的技术可能会导致发现更快的攻击。

北京安普诺信息技术有限公司

缺陷 1：

缺陷标识	2109526855502098433
风险点	python/crypto_util.py [6]
审计状态	

2.4. 系统风险等级-低危

2.4.1. 错误（质量缺陷）

缺陷名称：异常处理不当：过于宽泛的抛出

缺陷数量：4

缺陷介绍：

声明一种可以抛出 Exception 或 Throwable 异常的方法，从而使调用者很难处理和修复发生的错误。Java 异常机制的设置是: 调用者可以方便地预计有可能发生的各种错误，并为每种异常情况编写处理代码。同时声明：一个方法抛出一个过于笼统的异常违反该系统。

缺陷 1：

缺陷标识	2109526855531458563
风险点	src/main/java/com/govee/demo/PaymentService.java [9]
审计状态	

北京安普诺信息技术有限公司

缺陷 2：

缺陷标识	2109526855544041475
风险点	src/main/java/com/govee/demo/UserController.java [17]
审计状态	

缺陷 3：

缺陷标识	2109526855544041477
风险点	src/main/java/com/govee/demo/UserController.java [11]
审计状态	

缺陷 4：

缺陷标识	2109526855548235780
风险点	src/main/java/com/govee/demo/FileService.java [8]
审计状态	

北京安普诺信息技术有限公司